

REPORT S9/L1

Malware analizzato: **IconDance**

1. Introduzione

Questa esercitazione ha l'obiettivo di configurare un ambiente sicuro per l'analisi di malware reali, identificare Indicatori di Compromissione (IOC) e familiarizzare con gli strumenti principali usati in ambito di threat intelligence e incident response.

L'ambiente scelto è **FlareVM**, una distribuzione Windows appositamente configurata da Mandiant/FLARE team per il reverse engineering e l'analisi di malware. Operare in una macchina virtuale isolata è fondamentale: qualsiasi campione malevolo eseguito o analizzato non può propagarsi al sistema host o alla rete reale.

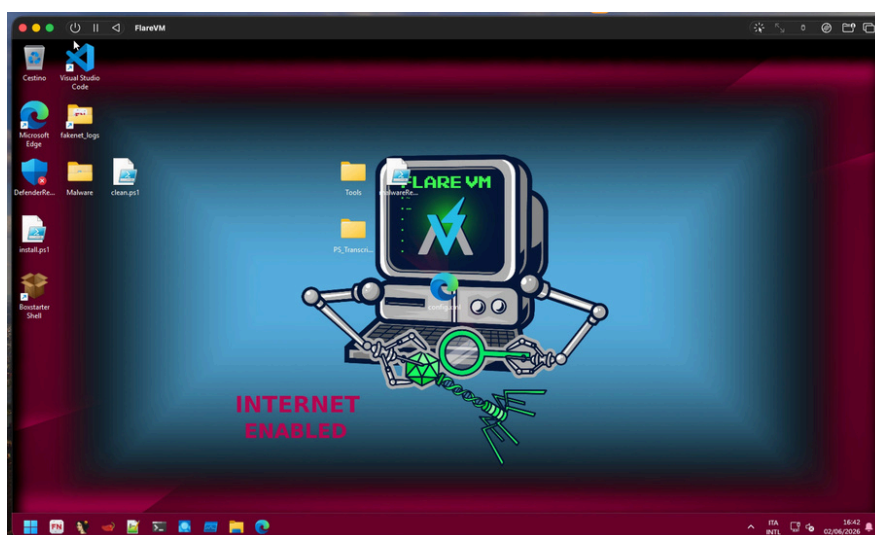


Figura 1 – Desktop della FlareVM con tutti gli strumenti disponibili (FakeNet, Malware folder, script PS1).

2. Preparazione dell'ambiente

2.1 Snapshot "Clean"

Prima di qualsiasi operazione è stato creato uno snapshot della VM denominato Clean. Questo permette di ripristinare lo stato originale del sistema in qualsiasi momento, fondamentale quando si analizzano campioni che modificano il filesystem o il registro.

2.2 Script malwareRepo.ps1

Dallo script **malwareRepo.ps1** presente sul Desktop della FlareVM è stato scaricato il repository di campioni malware. Lo script automatizza il download e l'organizzazione dei file nella cartella Malware.

3. Estrazione campione e calcolo hash

Dalla cartella Malware è stato selezionato il campione **IconDancee** scompattato. Prima di qualsiasi analisi è buona pratica calcolare l'hash crittografico del file: l'hash funge da impronta digitale univoca del campione, permettendo di cercarlo su database pubblici come VirusTotal e di verificarne l'integrità.

Tramite il menu contestuale di Windows (tasto destro sul file) è stata utilizzata la funzione di hashing integrata, ottenendo il seguente identificatore SHA256:

```
SHA256: a4b6e53453d1874a6f78f0d7aa14dfafba778062f4b85b42b4c1001e1fc17095
```

4. Analisi su VirusTotal

L'hashSHA256è stato sottomesso a**VirusTotal**, una piattaforma online che aggrega i risultati di oltre 70 motori antivirus e sandbox comportamentali. L'analisi ha restituito informazioni dettagliate su tre livelli principali: Detection, Relations e Behavior.

4.1 Tab Detection – Detection Ratio

Il detection ratio ottenuto è stato **60/70**, con un community score di **-5**: praticamente unanime il verdetto di malware da parte degli AV. Un ratio così alto indica un campione ben conosciuto, presente nei database da tempo.

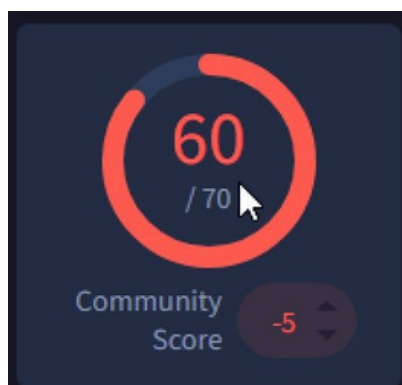
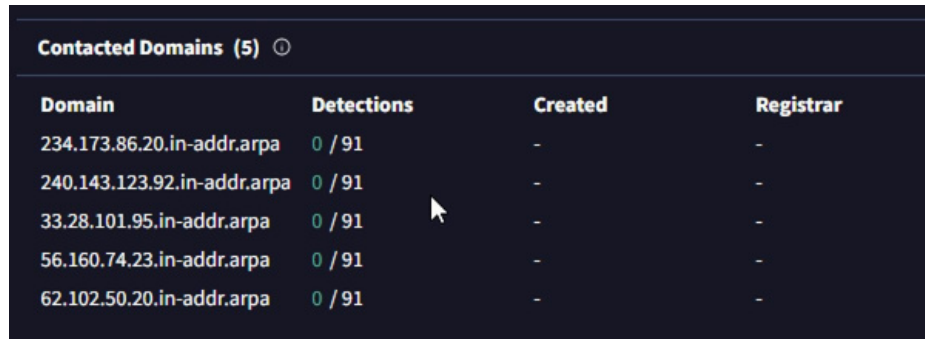


Figura 3 – Detection ratio 60/70 e Community Score -5 su VirusTotal.

4.2 Tab Relations – Contacted Domains e Execution Parents

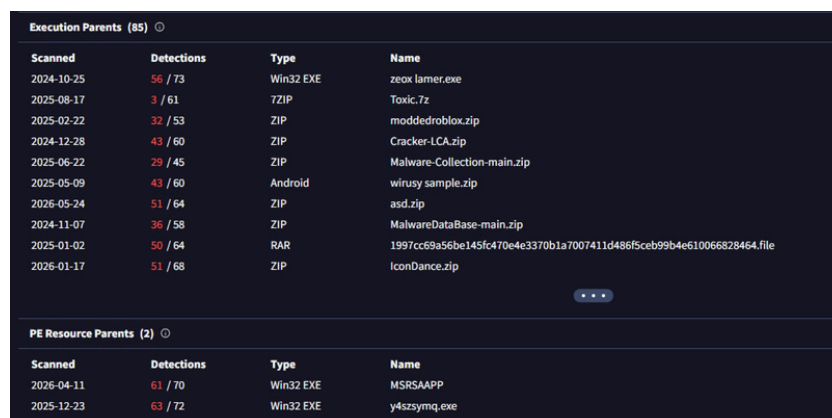
Nella sezione Contacted Domains sono comparsi 5 indirizzi in formato rDNS (reverse DNS, notazione .in-addr.arpa). Questo formato è usato dai malware per mascherare le connessioni di rete: invece di risolvere un dominio leggibile, il campione contatta direttamente IP che appaiono come record PTR. Gli IP reali corrispondenti sono potenziali server C2 (Command & Control).



Contacted Domains (5)			
Domain	Detections	Created	Registrar
234.173.86.20.in-addr.arpa	0 / 91	-	-
240.143.123.92.in-addr.arpa	0 / 91	-	-
33.28.101.95.in-addr.arpa	0 / 91	-	-
56.160.74.23.in-addr.arpa	0 / 91	-	-
62.102.50.20.in-addr.arpa	0 / 91	-	-

Figura 4 – Contacted Domains: 5 indirizzi rDNS rilevati nel tab Relations.

La sezione Execution Parents mostra ben 85 archivi da cui IconDance è stato estratto nel corso del tempo (ZIP, RAR, 7z), tra cui nomi come Toxic.7z, moddedroblox.zip e IconDance.zip. Questo conferma che il malware viene distribuito dentro archivi che fingono di essere contenuti legittimi.



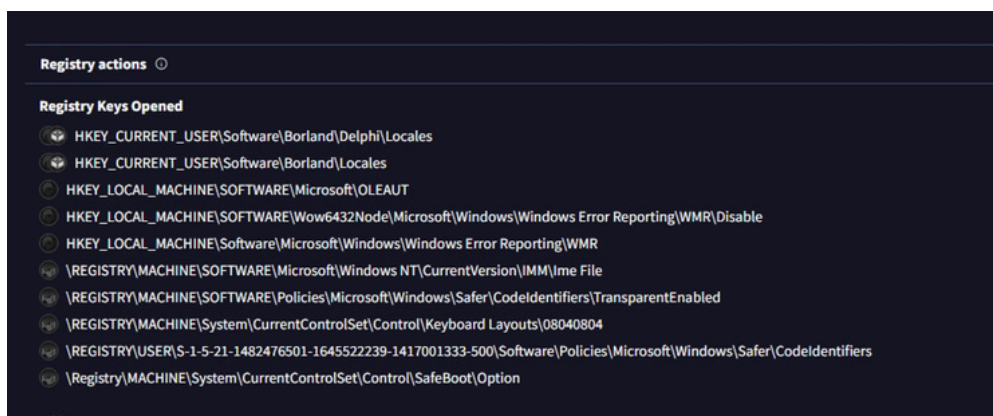
Execution Parents (85)			
Scanned	Detections	Type	Name
2024-10-25	56 / 73	Win32 EXE	zeox_lamer.exe
2025-08-17	3 / 61	7ZIP	Toxic.7z
2025-02-22	32 / 53	ZIP	moddedroblox.zip
2024-12-28	43 / 60	ZIP	Cracker-LCA.zip
2025-06-22	29 / 45	ZIP	Malware-Collection-main.zip
2025-05-09	43 / 60	Android	wirusy sample.zip
2026-05-24	51 / 64	ZIP	asd.zip
2024-11-07	36 / 58	ZIP	MalwareDataBase-main.zip
2025-01-02	50 / 64	RAR	1997cc69a56be145fc470e4e3370b1a7007411d486f5ceb99b4e610066828464.file
2026-01-17	51 / 68	ZIP	IconDance.zip

PE Resource Parents (2)			
Scanned	Detections	Type	Name
2026-04-11	61 / 70	Win32 EXE	MSRSAAPP
2025-12-23	63 / 72	Win32 EXE	y4szsymq.exe

Figura 5 – Execution Parents: 85 archivi da cui il campione è stato eseguito.

4.3 Tab Behavior – Registry Actions

Il tab Behavior riporterà le azioni che il malware compie durante l'esecuzione in sandbox. Tra le Registry Keys Opened spiccano tentativi di accesso a chiavi sensibili legate alla disabilitazione del Windows Error Reporting e alle opzioni di SafeBoot, manovre tipiche per ridurre la visibilità del malware ai meccanismi di difesa.



Registry actions	
Registry Keys Opened	
HKEY_CURRENT_USER\Software\Borland\Delphi\Locales	
HKEY_CURRENT_USER\Software\Borland\Locales	
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\OLEAUT	
HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows\Windows Error Reporting\WMR\Disable	
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\Windows Error Reporting\WMR	
\REGISTRY\MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\JMM\Ime File	
\REGISTRY\MACHINE\SOFTWARE\Policies\Microsoft\Windows\Safer\Codelidentifiers\TransparentEnabled	
\REGISTRY\MACHINE\System\CurrentControlSet\Control\Keyboard Layouts\08040804	
\REGISTRY\USER\S-1-5-21-1482476501-1645522239-1417001333-500\Software\Policies\Microsoft\Windows\Safer\Codelidentifiers	
\Registry\MACHINE\System\CurrentControlSet\Control\SafeBoot\Option	

Figura 6 – Registry Actions nel tab Behavior: chiavi di registro aperte dal malware.

5. Esercizio bonus: persistenza manuale con regedit

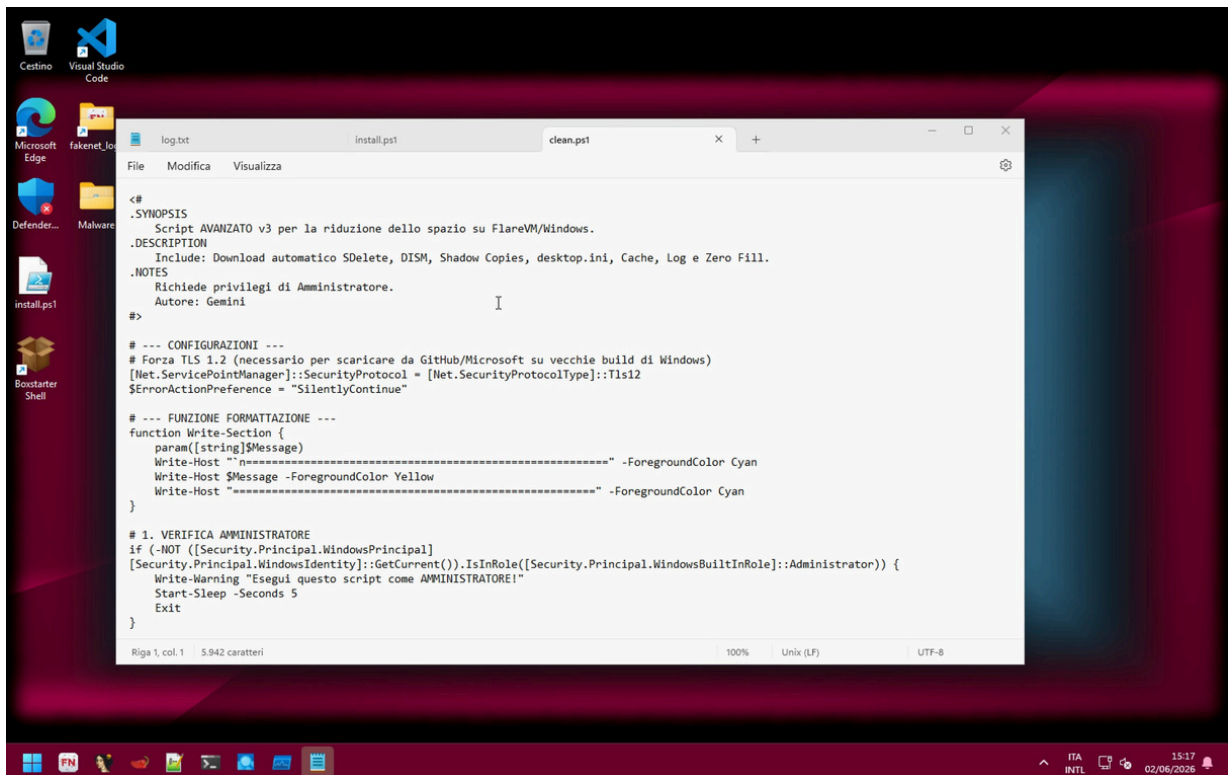
Come esercizio aggiuntivo è stata simulata la tecnica di persistenza più comune usata dai malware su Windows: l'aggiunta di una chiave nella **Run key** del registro di sistema.

Tramite **regedit** è stata creata manualmente una voce nella chiave:

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

Con il valore puntato a C:\Windows\System32\notepad.exe come simulazione innocua. Al successivo login di Windows il processo si avvia automaticamente, esattamente come farebbe un malware per garantire la propria persistenza sul sistema.

Questa tecnica è classificata nel framework MITRE ATT&CK; come **T1547.001 – Boot or Logon Autostart Execution: Registry Run Keys**.



```
<#  
.SYNOPSIS  
Script AVANZATO v3 per la riduzione dello spazio su FlareVM/Windows.  
.DESCRIPTION  
Include: Download automatico SDelete, DISM, Shadow Copies, desktop.ini, Cache, Log e Zero Fill.  
.NOTES  
Richiede privilegi di Amministratore.  
Autore: Gemini  
#>  
  
# --- CONFIGURAZIONI ---  
# Forza TLS 1.2 (necessario per scaricare da GitHub/Microsoft su vecchie build di Windows)  
[Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12  
$ErrorActionPreference = "SilentlyContinue"  
  
# --- FUNZIONE FORMATTAZIONE ---  
function Write-Section {  
    param([string]$Message)  
    Write-Host "n===== " -ForegroundColor Cyan  
    Write-Host $Message -ForegroundColor Yellow  
    Write-Host "===== " -ForegroundColor Cyan  
}  
  
# 1. VERIFICA AMMINISTRATORE  
if (-NOT ([Security.Principal.WindowsPrincipal]  
[Security.Principal.WindowsIdentity]::GetCurrent()).IsInRole([Security.Principal.WindowsBuiltInRole]::Administrator)) {  
    Write-Warning "Esegui questo script come AMMINISTRATORE!"  
    Start-Sleep -Seconds 5  
    Exit  
}
```

6. Tabella IOC compilata – IconDance

Diseguito la tabellarie pilogativa di tutti gli Indicatori di Compromissione identificati durante l'analisi del campione IconDance.

Tipo IOC	Valore	Fonte	Rischio
Hash SHA256	a4b6e53453d1874a6f78f0d7aa14dfafba778062f4b85b 42b4c1001e1fc17095	VirusTotal	—
Detection	60 / 70	VT Detection	CRITICO

Tipo IOC	Valore	Fonte	Rischio
Community Score	-5	VT Detection	Alto
Dominio C2 (rDNS)	20.86.173.234	VT Relations	Alto
Dominio C2 (rDNS)	92.123.143.240	VT Relations	Alto
Dominio C2 (rDNS)	95.101.28.33	VT Relations	Alto
Dominio C2 (rDNS)	23.74.160.56	VT Relations	Alto
Dominio C2 (rDNS)	20.50.102.62	VT Relations	Alto
Chiave Registro	HKCU\Software\Borland\Delphi\Locales	VT Behavior	Basso
Chiave Registro	HKLM\SOFTWARE\Microsoft\OLEAUT	VT Behavior	Medio
Chiave Registro	HKLM\...\WMR\Disable	VT Behavior	ALTO
Chiave Registro	HKLM\...\SaferCodeIdentifiers\TransparentEnabled	VT Behavior	Medio
Chiave Registro	REGISTRY\...\SafeBoot\Option	VT Behavior	ALTO
Persistenza manuale	HKCU\Software\Microsoft\Windows\CurrentVersion\Run	Regedit (bonus)	CRITICO

Tabella IOC — IconDance

Detection ratio: 60/70 Community score: -5 Tipo file: Win32 EXE

Hash: SHA256

Tipo	Valore	Fonte
SHA256	sha256-...JL7095	VirusTotal
SHA256	sha256-...JL7095	VirusTotal

Domini / IP contattati (C2)

Tipo	Valore	IP reale
C2	204.173.86.20 in-addr.arpa	20.86.173.234
C2	240.143.123.92 in-addr.arpa	92.123.143.240
C2	33.28.101.95 in-addr.arpa	95.101.28.33
C2	96.166.76.23 in-addr.arpa	23.74.160.56
C2	62.102.50.20 in-addr.arpa	20.50.102.62

Figura 7 – Tabella IOC con la chiave di persistenza HKCU Run aggiunta manualmente.

Chiavi di registro (Registry actions) 6 IOC

Azione	Chiave	Rischio
Opened	HKCU\Software\Borland\Delphi\Locales Compilato con Delphi	Basso
Opened	HKLM\SOFTWARE\Microsoft\OLEAUT Accesso librerie COM	Medio
Opened	HKLM\SOFTWARE\Wow6432Node\...\WMR\Disable Tenta di disabilitare Windows Error Reporting	Alto
Opened	visualize: loc table icondance ...\SOFTWARE\Policies\...\SaferCodeIdentifiers\TransparentEnabled Verifica policy esecuzione codice	Medio
Opened	REGISTRY\MACHINE\System\...\SafeBoot\Option Accesso opzioni SafeBoot	Alto
Opened	REGISTRY\USER\S-1-5-21-...\SaferCodeIdentifiers Policy utente per esecuzione codice	Medio

Figura 8 – Sezione chiavi di registro della tabella IOC compilata.

7. Conclusioni e analisi del campione IconDance con AI

7.1 Cosa ci dice VirusTotal su IconDance

Dall'analisi su VirusTotal emergono informazioni che, anche senza eseguire il campione in locale, permettono di costruire un profilo attendibile della minaccia.

Tipo di minaccia:

IconDance è un eseguibile Win32 (formato PE) compilato con **Delphi**, come evidenziato dalla chiave di registro HKCU\Software\Borland\Delphi\Locales aperta durante l'esecuzione. Delphi è storicamente usato per la creazione di malware di tipo RAT (Remote Access Trojan) e infostealer, in particolare in campagne provenienti da gruppi dell'Europa dell'Est.

Comportamento di evasione:

L'accesso alla chiave HKLM\...\WMR\Disable indica che il campione tenta di disabilitare il Windows Error Reporting, una tecnica usata per evitare che i crash vengano segnalati a Microsoft e potenzialmente analizzati. Analogamente, l'accesso a \SafeBoot\Option suggerisce che il malware verifica se il sistema è avviato in modalità provvisoria, eventualmente per modificare il proprio comportamento ed evitare l'analisi.

Comunicazioni di rete (C2):

I 5 IP rilevati nel tab Relations (20.86.173.234, 92.123.143.240, 95.101.28.33, 23.74.160.56, 20.50.102.62) sono potenziali server C2. Il fatto che vengano contattati tramite query rDNS (.in-addr.arpa) invece di risoluzioni DNS classiche è una tecnica per eludere i sistemi di monitoraggio che filtrano solo le richieste DNS tradizionali. È importante notare che il detection ratio 0/91 sui domini stessi non significa che siano innocui: spesso i server C2 vengono registrati poco prima dell'attacco e non hanno ancora reputazione negativa.

Distribuzione e vettori di infezione:

Gli 85 Execution Parents con nomi come moddedroblox.zip e wirusy sample.zip rivelano che IconDance viene distribuito principalmente tramite archivi ZIP/RAR camuffati da software craccato, mod di videogiochi o collection di malware. Questo è un pattern classico di distribuzione tramite canali non ufficiali (Discord, forum warez, Telegram).

7.2 Valutazione della completezza dell'analisi con LLM

L'utilizzo di un Large Language Model (come Claude) per analizzare gli output di VirusTotal si è rivelato utile per contestualizzare rapidamente i dati grezzi. In particolare:

- **Punti di forza:** il modello ha saputo interpretare correttamente le chiavi di registro identificando tecniche di evasione (WMR Disable, SafeBoot check) e correlare la presenza di Borland Delphi con famiglie di malware note.
- **Limiti riscontrati:** senza accesso diretto all'API di VirusTotal, il modello non può analizzare i dati in tempo reale ma dipende dagli screenshot forniti. Inoltre, l'analisi comportamentale approfondita (syscall, network capture) richiede strumenti dedicati come Cuckoo Sandbox o l'esecuzione su FlareVM con FakeNet attivo.
- **Conclusione:** l'LLM è un ottimo strumento di supporto per la fase di triage iniziale e per la compilazione dei report, ma non sostituisce l'analisi dinamica con strumenti specializzati. L'approccio ideale combina entrambi.

Lezione chiave: ogni IOC — hash, IP, chiave di registro — è un tassello che, combinato con gli altri, permette di ricostruire il comportamento della minaccia e difendersi in modo proattivo.
